PIIGuard Shield

Trợ lý AI rà soát và bảo vệ dữ liệu cá nhân trong PostgreSQL / MongoDB

Biệt đội ánh sáng - Team 138
Bản tổng hợp để chia sẻ qua Drive / GitHub Release. Nội dung chính đọc được trong PDF; các liên kết ngoài dùng để mở ứng dụng và xem bằng chứng chi tiết.

Dự án giải quyết việc gì?

Giúp doanh nghiệp tìm các trường dữ liệu cá nhân trước khi chia sẻ cho đội phân tích. Hệ thống đề xuất biện pháp bảo vệ, DPO duyệt, tạo snapshot riêng, kiểm tra tác vụ downstream rồi mới phát hành cho Analyst.

Thành viên	Phụ trách
Nguyễn Đình Phúc MHV: 2A202602953C401	Leader / PO; frontend, scope, demo và pitch
Trần Xuân Tùng MHV: 2A202602787C401	Rules / LLM; workflow phát hiện và đánh giá AI
Nguyễn Trung Kiên MHV: 2A202602764	MongoDB connector; fixture, nhãn chuẩn và eval
Đoàn Tuấn Long MHV: 2A202602609C401	Backend; PostgreSQL connector, guardrail và phân quyền

Mã học viên được ghi theo thông tin nhóm cung cấp. Mã của Nguyễn Trung Kiên giữ nguyên 2A202602764.

Mở demo

Ứng dụng production
Backend API | Swagger / tài liệu API

Tài khoản demo

DPO: **dpo / dpo123** Analyst: **analyst / analyst123**
Render free tier có thể cần khoảng 1 phút để khởi động. Đây là tài khoản demo do nhóm cung cấp; tài liệu không chứa API key hoặc mật khẩu database thật.

Thông tin tài liệu

Biên soạn ngày **17/10/2026** (giờ Việt Nam). Các chỉ số benchmark và test là số liệu báo cáo được lưu trong dự án, không phải kết quả kiểm tra live lúc xuất PDF. Danh mục pháp lý của dự án: Luật 91/2025/QH15, NĐ 356/2025/NĐ-CP và NĐ 13/2023/NĐ-CP.

Demo Day & luồng trình diễn

Hạn nộp theo thông tin nhóm cung cấp

23:00 ngày 18/10/2026 - giờ Việt Nam (UTC+7).
Chuẩn bị đủ link MVP, video, slide và thumbnail; kiểm tra quyền xem bằng cửa sổ ẩn danh.

Kịch bản 6 bước

01 - Đăng nhập DPO

Mở ứng dụng, dùng tài khoản DPO. Giải thích DPO là người rà soát và quyết định chính sách, AI chỉ đưa đề xuất.

02 - Chọn nguồn và phạm vi

Chọn PostgreSQL hoặc MongoDB, xem sơ đồ quan hệ và chọn bảng/collection cần quét. Nếu bỏ bảng liên quan, xem cảnh báo và cân nhắc thêm bảng liên kết.

03 - Quét và duyệt

Bấm bắt đầu quét. Xem phân loại, đề xuất action và rủi ro. Mở Inspector để duyệt hoặc sửa; ghi lý do khi ghi đè khuyến nghị. Dùng metadata và bằng chứng đã khử nhạy cảm để giải thích.

04 - Build, kiểm định, phát hành

Lưu quyết định và tạo snapshot. Tại tab Dữ liệu cho Analyst, xem preview và kết quả verifier. Chỉ phát hành khi hệ thống cho phép và verifier đạt.

05 - Giải thích biện pháp bảo vệ

Mở Demo che dữ liệu bằng dữ liệu synthetic; giới thiệu ma trận quy định và nhật ký kiểm toán. Đây là phần giải thích kỹ thuật, không thay cho bằng chứng của run thật.

06 - Đăng nhập Analyst

Mở dataset đã publish, xem dữ liệu theo bảng, sơ đồ ERD và xuất CSV nếu chức năng khả dụng. Chỉ ra HMAC giữ khóa nối nhất quán và các trường đã bị MASK/REDACT/DROP.

Lưu ý: dùng các nhãn nút tương ứng trên phiên bản đang chạy. Trong kịch bản demo, tránh ngoại lệ KEEP trên PII; phần giới hạn của cơ chế này được nêu ở trang 3.

Kiến trúc & cách bảo vệ dữ liệu

Luồng chính: nguồn dữ liệu → quét → DPO duyệt → snapshot riêng → verifier → publish → Analyst.

Khối	Trách nhiệm
Nguồn PostgreSQL / MongoDB	Đọc schema, kiểu dữ liệu, mẫu nội bộ và thống kê theo phạm vi được chọn.
Scanner + AI	Phát hiện PII, tạo nhãn và đề xuất action; không tự phê duyệt phát hành.
DPO workspace	4 tab: Tổng quan & phân loại PII; Rủi ro & đánh giá; Nhật ký kiểm toán; Dữ liệu cho Analyst.
Transform + snapshot	Áp dụng quyết định lên bản sao đích; giữ nguồn gốc và đầu ra tách biệt.
Verifier + Analyst	Kiểm tra JOIN / $lookup, một số kiểm tra rò rỉ và tính toàn vẹn; Analyst đọc snapshot đã publish theo quyền.

5 hành động cần giải thích trong demo

Action	Dùng khi nào
HMAC	Băm có khóa bí mật, nhất quán để giữ lookup / JOIN / mapping. Không phải mã hóa có thể giải mã.
MASK	Che giá trị theo implementation của từng loại field; không mặc định mọi field đều che một phần giống nhau.
REDACT	Thay thực thể PII trong văn bản bằng nhãn như [PHONE], giữ phần ngữ cảnh còn lại.
DROP	Loại bỏ field không cần chia sẻ hoặc có rủi ro cao khỏi output.
KEEP	Giữ nguyên giá trị. Ưu tiên dữ liệu phi cá nhân; ngoại lệ PII có giới hạn cần lưu ý bên dưới.

Phân quyền và giới hạn hiện tại

DPO rà soát metadata, thống kê và snapshot preview; Analyst chỉ đọc dataset đã publish theo quyền. Backend kiểm tra trạng thái và quyền, frontend hỗ trợ thao tác.

Giới hạn cần công bố

Backend hiện cho phép KEEP trên PII khi DPO có lý do và thời hạn ngoại lệ. Giá trị gốc khi đó có thể vào snapshot và Analyst xem được. Chưa có job tự thu hồi snapshot chỉ vì ngoại lệ hết hạn. Vì vậy không trình bày Zero Raw PII là bảo đảm tuyệt đối; verifier pass cũng không đồng nghĩa mọi rủi ro đã được loại bỏ.

AI & bằng chứng đánh giá

AI được dùng ở đâu?

AI tạo đề xuất phân loại và biện pháp bảo vệ cho từng field. Quyết định cuối cùng thuộc DPO. Rules-only vẫn là chế độ nền tảng; demo quét thành công không tự chứng minh đã gọi LLM.

Chế độ / luồng	Cách hoạt động
Rules-only	ENABLE_AI_SCAN=false: rules/regex và quy tắc field profile; không gọi LLM.
AI-assisted	ENABLE_AI_SCAN=true: field chưa chắc chắn có thể đi qua LLM. Đầu vào chỉ gồm metadata và thống kê đã lọc; không đưa raw sample_value vào prompt.
Luồng A - cấp cột	ColumnProfile có rules → BM25 → hybrid vector → LLM; FieldProfile có rules → LLM tùy chọn. Các graph không đồng nghĩa mọi run chạy đủ mọi tầng.
Luồng B - văn bản	Regex → FlashText dictionary → GLiNER zero-shot khi bật NER và có dependency. Quét mẫu trong RAM để đề xuất REDACT.
HITL memory	Ghi nhận một số quyết định DPO để hỗ trợ lần quét sau khi pipeline/cấu hình cho phép; không phải tự huấn luyện lại model sau mỗi lần duyệt.

Kết quả lưu trong báo cáo ngày 15/10/2026

Bộ đánh giá	Kết quả đã báo cáo
Luồng A, sau HITL	339 cột doanh nghiệp synthetic; Action Accuracy 100.00%.
Luồng B, GLiNER cascade	300 văn bản, 560 thực thể ground truth; Recall 97.86%, Precision 97.16%, F1 97.51%.
Kiểm thử ứng dụng	Báo cáo nghiệm thu ghi 317 backend tests + 160 frontend tests. Đây là số liệu tại thời điểm báo cáo, cần CI mới để xác nhận hiện trạng.

Cách đọc: Action Accuracy đo action đúng theo nhãn của bộ test; Recall đo tỷ lệ PII được tìm thấy; Precision đo tỷ lệ phát hiện đúng; F1 cân bằng Precision/Recall. Kết quả sau HITL trên bộ dữ liệu này chưa chứng minh độ chính xác tương tự trên dữ liệu doanh nghiệp mới.

Bằng chứng: Báo cáo Luồng A | Báo cáo Luồng B | AI Architecture

Deliverables & chuẩn bị nộp

Gate 2 - MVP

Hạng mục	Nội dung cần có / nguồn
Video E2E	PostgreSQL / MongoDB → DPO review → transform → audit → Analyst. Thư mục video nhóm cung cấp
Sơ đồ kiến trúc	Components và data flow. Nội dung chính tại trang 3; bản kiến trúc trong repo.
Lịch sử làm việc	Yêu cầu ≥ 10 PR merged; nhóm cung cấp con số 92, chưa xác minh live. Xem danh sách PR.
README / setup	Setup, biến môi trường, API và sample queries. Mở README.
Eval evidence	5 ca kiểm tra manual với output thực tế đã lưu. Mở bằng chứng Gate 2.

Demo Day - trạng thái đường dẫn

Tài sản	Trạng thái trước khi nộp
MVP	Mở ứng dụng
Video Demo Day	Chưa chốt link cuối. Thư mục video Gate 2 có sẵn; cần xác nhận clip nào là bản nộp.
Slide	Chưa cung cấp link; cần xuất PDF hoặc chia sẻ slide với quyền xem công khai phù hợp.
Thumbnail	Chưa cung cấp link; cần bổ sung.
Drive / Mã học viên	Đã có thư mục Drive công khai và mã học viên của 4 thành viên (trang 1).

Checklist trình diễn

1. Mở frontend và backend sớm, đăng nhập thử cả 2 vai trò.
2. Chuẩn bị nguồn synthetic kết nối được; chọn phạm vi demo nhỏ và rõ.
3. Kiểm tra một run quét/build/publish thật; xác nhận Analyst mở được output.
4. Giữ sẵn video và PDF này để trình bày khi app cold start hoặc mất mạng.
5. Mở link Drive / release ở cửa sổ ẩn danh; kiểm tra quyền xem và tải file.

Liên kết & cách chia sẻ PDF

Các tài liệu bên dưới có bản sao Google Drive với quyền xem qua liên kết. Có thể đọc nội dung trang 1-5 khi offline; ứng dụng, video và tài liệu chi tiết cần mạng.

Tài nguyên	Mở liên kết
MVP production	Mở MVP production
Backend API	Mở Backend API
Swagger	Mở Swagger
Video E2E	Mở Video E2E
Thư mục tài liệu công khai	Mở Thư mục tài liệu công khai
Brief Gate 1	Mở Brief Gate 1
PRD	Mở PRD
Wireframe / UI flow	Mở Wireframe / UI flow
Architecture	Mở Architecture
Demo 6 bước	Mở Demo 6 bước
AI Architecture	Mở AI Architecture
Báo cáo nghiệm thu P1	Mở Báo cáo nghiệm thu P1
Docs Index	Mở Docs Index
Gate 2 evidence	Mở Gate 2 evidence
Release / vận hành	Mở Release / vận hành

CI/CD cần hiểu đúng

GitHub Actions dùng self-hosted runner. Workflow ci.yml kiểm tra tích hợp; release-main.yml được kích hoạt theo cấu hình nhánh main. GitHub Release, backend Render và frontend Vercel là các bước khác nhau: deploy Render phụ thuộc hook/cách triển khai; production branch của Vercel cần cấu hình đúng.

Đưa lên Drive / Release

PDF và các tài liệu đã được sao lưu lên Drive, quyền người có liên kết chỉ xem. Có thể đính kèm PDF vào GitHub Release. Bản local: **docs/pdf/PIIGuard_Shield_Demo_Day.pdf**.

Bản sao Drive được chia sẻ ngày 17/10/2026; file Markdown/Draw.io là bản nguồn để tải về. PDF là bản tổng hợp, không chứa toàn bộ code/output từng test. Nguồn: hồ sơ nhóm, docs/core, demo flow và báo cáo performance/sau_HITL.